

IMAP / POP3

With the help of the [Internet Message Access Protocol \(IMAP\)](#), access to emails from a mail server is possible. Unlike the [Post Office Protocol \(POP3\)](#), IMAP allows online management of emails directly on the server and supports folder structures. Thus, it is a network protocol for the online management of emails on a remote server. The protocol is client-server-based and allows synchronization of a local email client with the mailbox on the server, providing a kind of network file system for emails, allowing problem-free synchronization across several independent clients. POP3, on the other hand, does not have the same functionality as IMAP, and it only provides listing, retrieving, and deleting emails as functions at the email server. Therefore, protocols such as IMAP must be used for additional functionalities such as hierarchical mailboxes directly at the mail server, access to multiple mailboxes during a session, and preselection of emails.

Clients access these structures online and can create local copies. Even across several clients, this results in a uniform database. Emails remain on the server until they are deleted. IMAP is text-based and has extended functions, such as browsing emails directly on the server. It is also possible for several users to access the email server simultaneously. Without an active connection to the server, managing emails is impossible. However, some clients offer an offline mode with a local copy of the mailbox. The client synchronizes all offline local changes when a connection is reestablished.

The client establishes the connection to the server via port [143](#). For communication, it uses text-based commands in [ASCII](#) format. Several commands can be sent in succession without waiting for confirmation from the server. Later confirmations from the server can be assigned to the individual commands using the identifiers sent along with the commands. Immediately after the connection is established, the user is authenticated by user name and password to the server. Access to the desired mailbox is only possible after successful authentication.

SMTP is usually used to send emails. By copying sent emails into an IMAP folder, all clients have access to all sent mails, regardless of the computer from which they were sent. Another advantage of the Internet Message Access Protocol is creating personal folders and folder structures in the mailbox. This feature makes the mailbox clearer and easier to manage. However, the storage space requirement on the email server increases.

Without further measures, IMAP works unencrypted and transmits commands, emails, or usernames and passwords in plain text. Many email servers require establishing an encrypted IMAP session to ensure greater security in email traffic and prevent unauthorized access to mailboxes. SSL/TLS is usually used for this purpose. Depending on the method and implementation used, the encrypted connection uses the standard port [143](#) or an alternative port such as [993](#).

Default Configuration

Both IMAP and POP3 have a large number of configuration options, making it difficult to deep dive into each component in more detail. If you wish to examine these protocol configurations deeper, we recommend creating a VM locally and install the two packages [dovecot-imapd](#), and [dovecot-pop3d](#) using [apt](#) and play around with the configurations and experiment.

In the documentation of Dovecot, we can find the individual [core settings](#) and [service configuration](#) options that can be utilized for our experiments. However, let us look at the list of commands and see how we can directly interact and communicate with IMAP and POP3 using the command line.

IMAP Commands

Command	Description
<code>1 LOGIN username password</code>	User's login.
<code>1 LIST "" *</code>	Lists all directories.

Command	Description
1 CREATE "INBOX"	Creates a mailbox with a specified name.
1 DELETE "INBOX"	Deletes a mailbox.
1 RENAME "ToRead" "Important"	Renames a mailbox.
1 LSUB "" *	Returns a subset of names from the set of names that the User has declared as being active or subscribed .
1 SELECT INBOX	Selects a mailbox so that messages in the mailbox can be accessed.
1 UNSELECT INBOX	Exits the selected mailbox.
1 FETCH <ID> all	Retrieves data associated with a message in the mailbox.
1 CLOSE	Removes all messages with the DeLeted flag set.
1 LOGOUT	Closes the connection with the IMAP server.

POP3 Commands

Command	Description
USER username	Identifies the user.
PASS password	Authentication of the user using its password.
STAT	Requests the number of saved emails from the server.
LIST	Requests from the server the number and size of all emails.
RETR id	Requests the server to deliver the requested email by ID.
DELE id	Requests the server to delete the requested email by ID.
CAPA	Requests the server to display the server capabilities.
RSET	Requests the server to reset the transmitted information.
QUIT	Closes the connection with the POP3 server.

Dangerous Settings

Nevertheless, configuration options that were improperly configured could allow us to obtain more information, such as debugging the executed commands on the service or logging in as anonymous, similar to the FTP service. Most companies use third-party email providers such as Google, Microsoft, and many others. However, some companies still use their own mail servers for many different reasons. One of these reasons is to maintain the privacy that they want to keep in their own hands. Many configuration mistakes can be made by administrators, which in the worst cases will allow us to read all the emails sent and received, which may even contain confidential or sensitive information. Some of these configuration options include:

Setting	Description
auth_debug	Enables all authentication debug logging.
auth_debug_passwords	This setting adjusts log verbosity, the submitted passwords, and the scheme gets logged.
auth_verbose	Logs unsuccessful authentication attempts and their reasons.
auth_verbose_passwords	Passwords used for authentication are logged and can also be truncated.

Setting	Description
auth_anonymous_username	This specifies the username to be used when logging in with the ANONYMOUS SASL mechanism.

Footprinting the Service

By default, ports 110, 143, 993, and 995 are used for IMAP and POP3. The two higher ports use TLS/SSL to encrypt the communication between client and server. Using Nmap, we can scan the server for these ports. The scan will return the corresponding information like what we see below if the server uses an embedded SSL certificate.

Nmap

Nmap

```
dbcypn@htb[/htb]$ sudo nmap 10.129.14.128 -sV -p110,143,993,995 -sC

Starting Nmap 7.80 ( https://nmap.org ) at 2021-09-19 22:09 CEST
Nmap scan report for 10.129.14.128
Host is up (0.00026s latency).

PORT      STATE SERVICE VERSION
110/tcp   open  pop3    Dovecot pop3d
|_pop3-capabilities: AUTH-RESP-CODE SASL STLS TOP UIDL RESP-CODES CAPA PIPELINING
|_ssl-cert: Subject: commonName=mail1.inlanefreight.htb/organizationName=Inlanefreight/stateOrProvinceName=California
|_Not valid before: 2021-09-19T19:44:58
|_Not valid after: 2295-07-04T19:44:58
143/tcp   open  imap    Dovecot imapd
|_imap-capabilities: more have post-login STARTTLS Pre-login capabilities LITERAL+ LOGIN-REFERRALS OK LOGINDISABLED
|_ssl-cert: Subject: commonName=mail1.inlanefreight.htb/organizationName=Inlanefreight/stateOrProvinceName=California
|_Not valid before: 2021-09-19T19:44:58
|_Not valid after: 2295-07-04T19:44:58
993/tcp   open  ssl/imap Dovecot imapd
|_imap-capabilities: more have post-login OK capabilities LITERAL+ LOGIN-REFERRALS Pre-login AUTH=PLAINA0001 SASL
|_ssl-cert: Subject: commonName=mail1.inlanefreight.htb/organizationName=Inlanefreight/stateOrProvinceName=California
|_Not valid before: 2021-09-19T19:44:58
|_Not valid after: 2295-07-04T19:44:58
995/tcp   open  ssl/pop3 Dovecot pop3d
|_pop3-capabilities: AUTH-RESP-CODE USER SASL(PLAIN) TOP UIDL RESP-CODES CAPA PIPELINING
|_ssl-cert: Subject: commonName=mail1.inlanefreight.htb/organizationName=Inlanefreight/stateOrProvinceName=California
|_Not valid before: 2021-09-19T19:44:58
|_Not valid after: 2295-07-04T19:44:58
MAC Address: 00:00:00:00:00:00 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.74 seconds
```

For example, from the output, we can see that the common name is mail1.inlanefreight.htb, and the email server belongs to the organization Inlanefreight, which is located in California. The displayed capabilities show us the commands available on the server and for the service on the corresponding port.

If we successfully figure out the access credentials for one of the employees, an attacker could log in to the mail server and read or even send the individual messages.

cURL

cURL

```
dbcypn@htb[/htb]$ curl -k 'imaps://10.129.14.128' --user user:p4ssw0rd

* LIST (\HasNoChildren) "." Important
* LIST (\HasNoChildren) "." INBOX
```

If we also use the **verbose** (**-v**) option, we will see how the connection is made. From this, we can see the version of TLS used for encryption, further details of the SSL certificate, and even the banner, which will often contain the version of the mail server.

cURL

```
dbcyph0n@htb[/htb]$ curl -k 'imaps://10.129.14.128' --user cry0l1t3:1234 -v

* Trying 10.129.14.128:993...
* TCP_NODELAY set
* Connected to 10.129.14.128 (10.129.14.128) port 993 (#0)
* successfully set certificate verify locations:
* CAfile: /etc/ssl/certs/ca-certificates.crt
* Capath: /etc/ssl/certs
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384
* Server certificate:
* subject: C=US; ST=California; L=Sacramento; O=Inlanefreight; OU=Customer Support; CN=mail1.inlanefreight.htb;
* start date: Sep 19 19:44:58 2021 GMT
* expire date: Jul 4 19:44:58 2295 GMT
* issuer: C=US; ST=California; L=Sacramento; O=Inlanefreight; OU=Customer Support; CN=mail1.inlanefreight.htb; e
* SSL certificate verify result: self signed certificate (18), continuing anyway.
* TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
* TLSv1.3 (IN), TLS handshake, Newsession Ticket (4):
* old SSL session ID is stale, removing
< * OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ AUTH=PLAIN] HTB-Academy IMAP4 v.0.21
> A001 CAPABILITY
< * CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ AUTH=PLAIN
< A001 OK Pre-login capabilities listed, post-login capabilities have more.
> A002 AUTHENTICATE PLAIN AGNyeTBsMXQzADEyMzQ=
< * CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE SORT SORT=DISPLAY THREAD=REFERENCES THREAD=REFS T
< A002 OK Logged in
> A003 LIST "" *
< * LIST (\HasNoChildren) "." Important
* LIST (\HasNoChildren) "." Important
< * LIST (\HasNoChildren) "." INBOX
* LIST (\HasNoChildren) "." INBOX
< A003 OK List completed (0.001 + 0.000 secs).
* Connection #0 to host 10.129.14.128 left intact
```

To interact with the IMAP or POP3 server over SSL, we can use **openssl**, as well as **ncat**. The commands for this would look like this:

OpenSSL - TLS Encrypted Interaction POP3

OpenSSL - TLS Encrypted Interaction POP3

```

dbcyph0n@htb[/htb]$ openssl s_client -connect 10.129.14.128:pop3s

CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight
verify error:num=18:self signed certificate
verify return:1
depth=0 C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight
verify return:1
---
Certificate chain
 0 s:C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight.

...SNIP...

---
read R BLOCK
---
Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol  : TLSv1.3
    Cipher    : TLS_AES_256_GCM_SHA384
    Session-ID: 3CC39A7F2928B252EF2FFA5462140B1A0A74B29D4708AA8DE1515BB4033D92C2
    Session-ID-ctx:
    Resumption PSK: 68419D933B5FEBD878FF1BA399A926813BEA3652555E05F0EC75D65819A263AA25FA672F8974C37F6446446BB7EA8
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 7200 (seconds)
    TLS session ticket:
0000 - d7 86 ac 7e f3 f4 95 35-88 40 a5 b5 d6 a6 41 e4    ...~...5.@....A.
0010 - 96 6c e6 12 4f 50 ce 72-36 25 df e1 72 d9 23 94    .L..OP.r6%.r.#.
0020 - cc 29 90 08 58 1b 57 ab-db a8 6b f7 8f 31 5b ad    .).X.W...k..1[.
0030 - 47 94 f4 67 58 1f 96 d9-ca ca 56 f9 7a 12 f6 6d    G..gX....V.z..m
0040 - 43 b9 b6 68 de db b2 47-4f 9f 48 14 40 45 8f 89    C..h...60.H.@E..
0050 - fa 19 35 9c 6d 3c a1 46-5c a2 65 ab 87 a4 fd 5e    ..5.m<.F\..e....^
0060 - a2 95 25 d4 43 b8 71 70-40 6c fe 6f 0e d1 a0 38    ..%.C.qp@l.o...8
0070 - 6e bd 73 91 ed 05 89 83-f5 3e d9 2a e0 2e 96 f8    n.s.....>.*....
0080 - 99 f0 50 15 e0 1b 66 db-7c 9f 10 80 4a a1 8b 24    ..P...f.|...J..$
0090 - bb 00 03 d4 93 2b d9 95-64 44 5b c2 6b 2e 01 b5    .....+..dD[.k...
00a0 - e8 1b f4 a4 98 a7 7a 7d-0a 80 cc 0a ad fe 6e b3    .....z}.....n.
00b0 - 0a d6 50 5d fd 9a b4 5c-28 a4 c9 36 e4 7d 2a 1e    ..P]...\.6.}*..

    Start Time: 1632081313
    Timeout    : 7200 (sec)
    Verify return code: 18 (self signed certificate)
    Extended master secret: no
    Max Early Data: 0
---
read R BLOCK
+OK HTB-Academy POP3 Server

```

OpenSSL - TLS Encrypted Interaction IMAP

OpenSSL - TLS Encrypted Interaction IMAP

```

dbcyph0n@htb[/htb]$ openssl s_client -connect 10.129.14.128:imaps

CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight
verify error:num=18:self signed certificate
verify return:1
depth=0 C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight
verify return:1
---
Certificate chain
 0 s:C = US, ST = California, L = Sacramento, O = Inlanefreight, OU = Customer Support, CN = mail1.inlanefreight.
...SNIP...

---
read R BLOCK
---
Post-Handshake New Session Ticket arrived:
SSL-Session:
    Protocol  : TLSv1.3
    Cipher    : TLS_AES_256_GCM_SHA384
    Session-ID: 2B7148CD1B7B92BA123E06E22831FCD3B365A5EA06B2CDEF1A5F397177130699
    Session-ID-ctx:
    Resumption PSK: 4D9F082C6660646C39135F9996DDA2C199C4F7E75D65FA5303F4A0B274D78CC5BD3416C8AF50B31A34EC022B619CC
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 7200 (seconds)
    TLS session ticket:
    0000 - 68 3b b6 68 ff 85 95 7c-8a 8a 16 b2 97 1c 72 24    h;.h...|.....r$
    0010 - 62 a7 84 ff c3 24 ab 99-de 45 60 26 e7 04 4a 7d    b....$...E`&..J}
    0020 - bc 6e 06 a0 ff f7 d7 41-b5 1b 49 9c 9f 36 40 8d    .n.....A..I..6@.
    0030 - 93 35 ed d9 eb 1f 14 d7-a5 f6 3f c8 52 fb 9f 29    .5.....?.R..)
    0040 - 89 8d de e6 46 95 b3 32-48 80 19 bc 46 36 cb eb    ...F..2H...F6..
    0050 - 35 79 54 4c 57 f8 ee 55-06 e3 59 7f 5e 64 85 b0    5yTLW..U..Y.^d..
    0060 - f3 a4 8c a6 b6 47 e4 59-ee c9 ab 54 a4 ab 8c 01    .....G.Y...T....
    0070 - 56 bb b9 bb 3b f6 96 74-16 c9 66 e2 6c 28 c6 12    V...;..t..f.l(..
    0080 - 34 c7 63 6b ff 71 16 7f-91 69 dc 38 7a 47 46 ec    4.ck.q...i.8zGF.
    0090 - 67 b7 a2 90 8b 31 58 a0-4f 57 30 6a b6 2e 3a 21    g....1X.0W0j...!
    00a0 - 54 c7 ba f0 a9 74 13 11-d5 d1 ec cc ea f9 54 7d    T....t.....T}
    00b0 - 46 a6 33 ed 5d 24 ed b0-20 63 43 d8 8f 14 4d 62    F.3.]$.. cC...Mb

    Start Time: 1632081604
    Timeout    : 7200 (sec)
    Verify return code: 18 (self signed certificate)
    Extended master secret: no
    Max Early Data: 0
---
read R BLOCK
* OK [CAPABILITY IMAP4rev1 SASL-IR LOGIN-REFERRALS ID ENABLE IDLE LITERAL+ AUTH=PLAIN] HTB-Academy IMAP4 v.0.21.4

```

Once we have successfully initiated a connection and logged in to the target mail server, we can use the above commands to work with and navigate the server. We want to point out that the configuration of our own mail server, the research for it, and the experiments we can do together with other community members will give us the know-how to understand the communication taking place and what configuration options are responsible for this.

In the SMTP section, we have found the user `robin`. Another member of our team was able to find out that the user also uses his username as a password (`robin:robin`). We can use these credentials and try them to interact with the IMAP/POP3 services.

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

∞ / 1 spawns left

Waiting to start..

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: 10.129.168.241 

Life Left: 65 minutes 

 Cheat Sheet

 Download VPN Connection File

 +1 Figure out the exact organization name from the IMAP/POP3 service and submit it as the answer.

Submit your answer here...

 Submit

 +1 What is the FQDN that the IMAP and POP3 servers are assigned to?

Submit your answer here...

 Submit

 +1 Enumerate the IMAP service and submit the flag as the answer. (Format: HTB{...})

Submit your answer here...

Submit

+ 1  What is the customized version of the POP3 server?

Submit your answer here...

Submit

+ 1  What is the admin email address?

Submit your answer here...

Submit

+ 1  Try to access the emails on the IMAP server and submit the flag as the answer. (Format: HTB{...})

Submit your answer here...

Submit

← Previous

Next →

 Cheat Sheet

 Resources

 Go to Questions

Table of Contents

Introduction

Enumeration Principles	✓
Enumeration Methodology	✓

Infrastructure Based Enumeration

Domain Information	✓
Cloud Resources	✓
Staff	✓

Host Based Enumeration

 FTP	✓
 SMB	✓
 NFS	✓
 DNS	✓

 SMTP

 IMAP / POP3

 SNMP

 MySQL

 MSSQL

 Oracle TNS

 IPMI



Remote Management Protocols

- Linux Remote Management Protocols
- Windows Remote Management Protocols

Skills Assessment

-  Footprinting Lab - Easy
-  Footprinting Lab - Medium
-  Footprinting Lab - Hard

My Workstation

OFFLINE

 Start Instance

∞ / 1 spawns left